CYBERINFINITI LTD

GOVERNANCE, RISK & COMPLIANCE

Enterprise Information Security Policy Development & Compliance Framework Implementation Report

---

Organization: Cyberinfiniti ltd.

Report ID: CIF-GRC-PDCR-2026-02

Report Date: February 2026

Classification: Confidential / Internal Use

Analysts: John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Blessing Ibe, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun.

Reviewed By: Chief Information Security Officer (CISO)

Approved By: Managing Director

Report Version: 1.0

Distribution: CyBlack Team, SOC Team, Executive Management,

Table of Contents

1.0 Executive Summary **6**
2.0 Organizational Context 7
3.0 Objectives **8**
4.0 Policy Development Methodology **8**
Phase 1: Governance Gap Assessment 8
Phase 2: Regulatory & Standards Alignment 8
Phase 3: Risk Contextualization 9
Phase 4: Policy Drafting & Structuring 9
Phase 5: Governance Role Assignment 10
Phase 6: Compliance Framework Integration 11
5.0 Expanded Overview of Developed Policies **12**
5.1 Information Security Policy 12
Information Security Policy **14**
1. Overview and Purpose 14
2. Scope and Definition of Information Security 14
3. Roles and Responsibilities 14
4. Governance and Policy Framework 15
4.1 Management Commitment 15
4.2 Risk-Based Approach 15
4.3 Regulatory and Legal Compliance 15
4.4 Supporting Policies 15
4.5 Assignment of Responsibilities 15
4.6 Continual Improvement 15
4.7 Exception Management 16
5. Monitoring, Compliance, and Enforcement 16
6. Policy Review 16
7. Communication and Awareness 16
8. Continual Improvement Commitment 17
Conclusion 17
5.2 Information Classification Policy 18
Information Classification Policy **19**
1. PURPOSE 19
2. SCOPE 19
3. ISO/IEC 27002:2022 CONTROL ALIGNMENT 19
4.INFORMATION CLASSIFICATION FRAMEWORK 20
5. CLASSIFICATION & LABELLING REQUIREMENTS 21
6. HANDLING & STORAGE CONTROLS 21
7. REGULATORY COMPLIANCE 22
8. ROLES & RESPONSIBILITIES 22
9. EXCEPTIONS 22

10. MONITORING & ENFORCEMENT 22
11. TRAINING & AWARENESS 23
12. CONTINUAL IMPROVEMENT 23
13. POLICY ACKNOWLEDGEMENT 23
Conclusion 23
5.3 Identity Management and Access Control Policy 24
IDENTITY MANAGEMENT & ACCESS CONTROL POLICY 25
1. Purpose 25
2. Organisational Context 25
3. Scope 25
4. IAM Framework Definition 25
5. IAM Objectives 26
6. Policy Statements 26
6.1 Governance 26
6.2 Identity Lifecycle Management 26
6.3 Authentication Security 26
6.4 Access Control 26
6.5 Compliance 27
6.6 Auditability 27
6.7 Continual Improvement 27
6.8 Exception Management 27
7. Roles & Responsibilities 27
8. Monitoring, Compliance & Enforcement 27
9. Communication & Awareness 28
10. Policy Review & Continual Improvement 28
11. ALIGNMENT WITH ISO/IEC 27002:2022 28
Conclusion 29
5.4 Privileged Account Management Policy 30
Privileged Access Management (PAM) Policy 31
1. Purpose 31
2. Scope 31
3. Key Definitions 31
4. Objectives 31
5. Policy Framework 32
6. Incident Handling 32
7. Compliance & Enforcement 32
8. Roles & Responsibilities 32
9. Key Compliance Metrics 33
10. Continual Improvement 33
Conclusion 33
5.5 Artificial Intelligence Governance Policy 34

Artificial Intelligence (AI) Policy **35**
1. Purpose 35
2. Scope 35
3. Roles and Responsibilities 35
4. Policy Statements 35
4.1 Acceptable Use 35
4.1.1 Prohibited Use 36
4.2 Risk Management 36
4.3 Data Protection & Privacy 36
4.4 Security Requirements 36
4.5 Third-Party AI 36
4.6 Monitoring & Compliance 36
5. Compliance & Alignment 36
6. Review 37
7. Enforcement 37
Conclusion 37
5.6 Incident Management Policy 38
Incident Management Policy **39**
1. Purpose 39
2. Organizational Context 39
3. Scope 39
4. Definitions 39
5. Incident Management Objectives 39
6. Incident Management Framework 40
6.1 Planning and Preparation 40
6.2 Detection and Reporting 40
6.3 Assessment and Classification 40
6.4 Response and Containment 40
6.5 Eradication and Recovery 40
6.6 Lessons Learned 40
6.7 Evidence Collection 40
7. Roles and Responsibilities 40
8. Policy Review and Maintenance 41
9. Communication and Awareness 41
10. Enforcement 41
Conclusion 41
5.7 Clear Desk & Clear Screen Policy 42
CLEAR DESK & CLEAR SCREEN POLICY **43**
1. Purpose 43
2. Scope 43
3. Policy Requirements 43

3.1 Clear Desk Requirements....43
3.2 Clear Screen Requirements.... 43
4. Standards & Regulatory Alignment....44
ISO Alignment....44
Regulatory Requirements.... 44
Industry Standards....44
5. Monitoring & Compliance....44
6. Enforcement & Sanctions.... 44
7. Review & Continuous Improvement.... 45
8. Roles & Responsibilities.... 45
Conclusion....45
5.8 Third-Party & Vendor Risk Management Policy....46
Third Party &Vendor Management Policy.... 47
1. Organisational Context.... 47
2. Purpose.... 47
3. Scope....47
4. Governance & Roles....47
5. Vendor Risk Management Framework.... 48
6. Policy Requirements....48
6.1 Supplier Due Diligence.... 48
6.2 Contractual Security Controls.... 48
6.3 Access Management.... 48
6.4 Monitoring & Review....49
6.5 Incident Management.... 49
6.6 Supplier Termination.... 49
7. Compliance & Regulatory Alignment....49
8. Monitoring, Enforcement & Metrics....49
9. Exceptions & Governance Control....50
10. Continuous Improvement....50
Conclusion....50
5.9 Vulnerability Management & Secure Testing Policy....51
Vulnerability Management & Secure Testing Policy Summary.... 52
1. Overview and Organisational Context.... 52
2. Purpose and Scope.... 52
3. Governance and Policy Requirements.... 52
4. Vulnerability Management Framework.... 53
4.1 Identification and Scanning....53
4.2 Risk Classification and Remediation.... 53
4.3 Tracking and Reporting....53
5. Configuration and Secure Testing Controls.... 54
5.1 Configuration Management.... 54

5.2 Secure Testing Practices..... 54
6. Change Management and Exception Handling..... 54
7. Compliance, Monitoring, and Reporting..... 55
8. Roles, Responsibilities, and Incident Integration..... 55
9. Training, Review, and Continuous Improvement..... 55
Conclusion..... 56
5.10 Business Continuity & Disaster Recovery Policy..... 57
BUSINESS CONTINUITY & DISASTER RECOVERY POLICY..... 58
1. Purpose..... 58
2. Scope..... 58
3. Policy Statement..... 58
4. Business Impact Analysis (BIA)..... 59
5. ICT Readiness & Resilience..... 59
6. Backup & Recovery Management..... 59
7. Disaster Recovery & Crisis Management..... 60
8. Testing & Continuous Improvement..... 60
9. Regulatory & Contractual Alignment..... 60
10. Roles & Responsibilities..... 60
11. Monitoring, Compliance & Review..... 61
Conclusion..... 61
6.0 Pictorial Representation of Developed Policies..... 62
7.0 Integrated Compliance & Monitoring Model..... 63
7.1 Pictorial Representation of Policy Governance Structure..... 64
8.0 Domain, Sub-Domain & Control Mapping (ISO/IEC 27002:2022)..... 65
9.0 NDPA 2023 Regulatory Integration..... 66
10.0 Executive Risk Insights..... 67
11.0 Strategic Recommendations..... 68
12.0 Conclusion..... 69
Appendix A: Sprint Timeline & Meetings..... 70
Appendix B: Team Contributions..... 71

1.0 Executive Summary

This report presents the outcome of a structured Governance, Risk, and Compliance (GRC) policy development conducted for **Cyberinfiniti Ltd**, a cybersecurity-focused enterprise delivering managed security services, cloud advisory, vulnerability assessments, and governance consulting.

The primary objective of this sprint was to design, formalize, and implement a structured enterprise Information Security Policy Framework aligned to:

- **ISO/IEC 27002:2022**
- **Nigeria Data Protection Act (NDPA) 2023**
- Client contractual security obligations
- Industry best practices for cybersecurity service providers

Prior to this sprint, Cyberinfiniti Ltd operated with operational security controls but lacked a centralized, documented, and formally approved policy framework. This presented governance, regulatory, and assurance gaps.

Ten core enterprise security policies were developed, structured, and integrated into a measurable compliance framework. Each policy was:

- Assigned defined governance roles (Author, Owner, Reviewer, Approver)
- Mapped to ISO/IEC 27002:2022 domains and controls
- Aligned with NDPA data protection requirements
- Integrated into a continuous monitoring model
- Structured for executive visibility and audit defensibility

The result is a scalable governance framework that enhances security maturity, risk management capability, regulatory posture, and organizational resilience.

2.0 Organizational Context

Cyberinfiniti Ltd operates within a high-trust, high-sensitivity environment, providing:

- Security Operations Center (SOC) services
- Threat detection & monitoring
- Vulnerability Assessment & Penetration Testing
- Cloud security advisory
- Governance, Risk & Compliance consulting
- Security awareness and professional training

As a cybersecurity firm, Cyberinfiniti handles:

- Client infrastructure configurations
- Threat intelligence feeds
- Sensitive security reports
- Vulnerability data
- Compliance documentation
- Personal data under NDPA scope

This creates elevated exposure to:

- Data breach risks
- Reputational damage
- Operational disruption
- Regulatory sanctions and legal consequences
- Financial loss and contractual liabilities
- Loss of client trust and business continuity disruption

Therefore, a formalized governance structure is not optional, it is a strategic necessity.

3.0 Objectives

The objectives were to:

1. Develop 10 enterprise security policies tailored to Cyberinfiniti Ltd's operational model.
2. Align policies to ISO/IEC 27002:2022 domains and control requirements.
3. Integrate NDPA 2023 data protection obligations.
4. Define policy ownership and governance accountability.
5. Establish a measurable compliance monitoring structure.
6. Create executive-ready reporting and audit artifacts.
7. Support long-term ISO 27001 certification readiness.

4.0 Policy Development Methodology

A structured six-phase methodology was adopted:

Phase 1: Governance Gap Assessment

This phase entails identifying gaps between our organisation's current governance, risk, and compliance (GRC) practices and the requirements of:

- ISO/IEC 27001
- ISO/IEC 27002:2022
- Applicable regulatory and business requirements

It covers:

- Policies and procedures
- Roles and responsibilities
- Risk management processes
- Security controls implementation
- Compliance obligations

Basically in this phase, 3 things are looked at

- Identified absence of documented policy framework
- Assessed operational risks and maturity level
- Reviewed current informal controls

Phase 2: Regulatory & Standards Alignment

Aligning regulations and standards guarantees that our organization's operations, procedures, and policies adhere to worldwide best practices, industry standards, and the law. This is

essential to a cybersecurity and compliance firm such as ours where reputation, audit readiness, and client confidence, it is not optional.

In this phase,

- ISO/IEC 27002:2022 domains are reviewed
- Policies are mapped to NDPA 2023 obligations (lawful processing, breach notification, data security)
- Client compliance requirements are considered as well

Phase 3: Risk Contextualization

Risk contextualization is the process of identifying, analysing, and interpreting risks within the specific operational, regulatory, and threat landscape of the organisation, not just in theory, but in how they actually affect our business. For a cybersecurity and compliance firm like CyberInfiniti Ltd, this means aligning risks with services, clients, data sensitivity, and threat exposure.

The objective is to:

- Ensure risks are relevant to business operations
- Prioritise risks based on real impact and likelihood
- Support decision-making in line with ISO/IEC 27002:2022
- Enable effective control selection and implementation

Risks specific to Cyberinfiniti identified:

- Privileged account abuse
- Inadequate vendor oversight
- Vulnerability remediation delays
- Inconsistent incident reporting
- Business continuity exposure

Phase 4: Policy Drafting & Structuring

Policy drafting isn't just writing rules, it's about creating clear, enforceable, and auditable documents that align with business objectives, risks, and standards like ISO/IEC 27001 and ISO/IEC 27002:2022. Policy statements MUST BE MANDATORY, TESTABLE & CONTROL DRIVEN.

Each policy included:

- **Purpose**: It defines the objective of the policy. It explains why the policy exists and what it aims to achieve in supporting business goals, risk management, and compliance.

- **Scope**: It outlines the policy's boundaries and areas of application. It recognizes: Who is covered by the policy, such as third parties, contractors, and employees. Which activities, data, systems, or processes are covered?
- **Definitions**: Provides clarity on key terms and concepts used within the policy. This ensures consistent understanding of technical, legal, or domain-specific language across our organisation.
- **Roles & Responsibilities**: Defines accountability and ownership for implementing, enforcing, and complying with the policy. It assigns specific duties to roles such as management, security teams, and users.
- **Policy Statements**: This is the core mandatory requirements of the policy. These are enforceable rules written in clear terms that specify what must or must not be done.
- **Monitoring & Compliance**: Describes how adherence to the policy is measured, tracked, and reviewed,which includes Audits and assessments, Compliance checks against standards like ISO/IEC 27001
- **Enforcement & Sanctions**: This outlines the consequences of non-compliance with these policies. This may include disciplinary actions, access restrictions, or legal consequences, depending on severity.
- **Review Schedule**: Defines how often the policy is reviewed and updated to remain relevant.
  Typically includes: Periodic review (e.g., annually) or Trigger-based review (e.g., after incidents, regulatory changes, or major system updates)

Phase 5: Governance Role Assignment

Governance role assignment defines who is responsible, accountable, consulted, and informed for security, risk, and compliance activities across the organisation. It ensures clear ownership, decision-making authority, and accountability, as required by ISO/IEC 27001 and ISO/IEC 27002:2022 (Control 5.2 – Roles & Responsibilities).It ensures that all information security, AI governance, and compliance activities have clearly defined ownership and accountability, reducing gaps and overlaps in responsibilities.

In this phase, different roles were assigned to members of the team as follows:

- **Managing Director**: John Ofulue
- **CISO**: Ikenna Emerole
- **GRC Manager**: Halimat Adepegba
- **SOC Manager**: Ayodimeji Omole
- **IAM Specialist**: Odunayo Balogun
- **Head of Security Engineering**: Favour Obisike
- **IT Operations Lead**: Andrew Moses
- **HR Manager**: Blessing Ibe
- **Legal & Compliance Officer**: Divine Ezewele

Phase 6: Compliance Framework Integration

Compliance Framework Integration is the process of aligning organisational policies, controls, and processes with multiple regulatory and industry standards in a unified, structured way. Instead of treating each regulation separately, a single, coordinated compliance system is created.

It is done to ensure that all security and compliance activities:

- Are consistent across the organisation
- Avoid duplication of controls
- Support business operations efficiently
- Align with standards like ISO/IEC 27001 and ISO/IEC 27002:2022

It helps to

- Reduces compliance cost
- Improves audit readiness
- Strengthens governance
- Enhances visibility of risks and controls

In this phase:

- Monitoring frequency is defined
- Evidence requirements are documented
- Reporting lines are established
- Exception handling processe are formalized

5.0 Expanded Overview of Developed Policies

Below is a more detailed breakdown cutting across all policies:

5.1 Information Security Policy

Below is the approved Information Security Policy for Cyberinfiniti Ltd.

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Information Security Policy
Document ID	CIL-GRC-STRAT-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5 (Organizational Controls)
Control Reference/Sub-Domain	5.1 – Policies for Information Security
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer	Managing Director
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____

For: Cyberinfiniti Ltd

Information Security Policy

1. Overview and Purpose

The Information Security Policy establishes the formal governance framework for managing and protecting information assets within Cyberinfiniti Ltd. It defines management direction, strategic objectives, and organisational commitment to safeguarding sensitive information in alignment with international standards such as ISO/IEC 27002:2022, regulatory requirements including Nigeria Data Protection Act 2023, and applicable contractual obligations.

The policy is designed to ensure the **confidentiality, integrity, and availability (CIA)** of information assets while supporting business continuity and operational resilience. It also ensures that information security practices remain appropriate, effective, and continuously improved in response to evolving risks and regulatory expectations.

2. Scope and Definition of Information Security

The policy applies to:

- All employees, contractors, and consultants
- Third-party service providers
- All organisational information assets
- All systems, networks, devices, and cloud environments

Information security within this context is defined by the protection of:

- **Confidentiality** – preventing unauthorized access to information
- **Integrity** – ensuring accuracy and completeness of data
- **Availability** – ensuring reliable access to systems and information when needed

These principles guide all security controls and decision-making processes within the organisation.

3. Roles and Responsibilities

Effective governance requires clear accountability across all levels:

- **Managing Director** – Provides executive oversight and approves policies
- **Chief Information Security Officer (CISO)** – Owns the policy and leads security strategy
- **GRC Manager** – Develops policies and monitors compliance
- **SOC Manager** – Oversees operational security monitoring and response
- **IAM Specialist** – Manages identity and access controls
- **IT Operations Lead** – Ensures infrastructure security
- **All Employees** – Responsible for adhering to policy requirements

This structured assignment of roles ensures accountability, segregation of duties, and effective control implementation.

4. Governance and Policy Framework

In alignment with ISO/IEC 27002:2022 Control 5.1, the organisation adopts a structured governance approach based on the following principles:

4.1 Management Commitment

Top management provides visible leadership and support for information security initiatives, ensuring adequate resources and strategic direction.

4.2 Risk-Based Approach

Security controls are implemented based on formal risk assessments, ensuring that resources are prioritised according to actual risk exposure.

4.3 Regulatory and Legal Compliance

The organisation ensures compliance with all applicable laws, regulations, and contractual obligations, including Nigeria Data Protection Act 2023.

4.4 Supporting Policies

This policy is supported by a suite of **topic-specific policies**, including:

- Access Control Policy
- Incident Management Policy
- Information Classification Policy
- Vulnerability Management Policy
- Business Continuity Policy
- AI Governance Policy

4.5 Assignment of Responsibilities

Information security responsibilities are clearly defined and assigned to appropriate roles across the organisation.

4.6 Continual Improvement

The ISMS is continuously improved through:

- Audit findings
- Risk assessments
- Incident analysis

- Regulatory updates
- Management reviews

4.7 Exception Management

All deviations from policy must be:

- Documented
- Risk assessed
- Approved by the CISO
- Periodically reviewed**.**

5. Monitoring, Compliance, and Enforcement

Compliance with this policy is actively monitored through:

- Internal audits
- Access and control reviews
- Incident reporting and trend analysis
- Risk assessments
- Executive-level reporting

Failure to comply may result in:

- Disciplinary action for employees
- Contract termination for third parties
- Legal consequences where applicable

This ensures that the policy is not only defined but also **enforced and measurable**.

6. Policy Review

To remain effective and relevant, the policy is subject to:

- Annual review
- Updates following significant business or technological changes
- Revisions after major security incidents
- Adjustments based on regulatory developments

The review process considers:

- Audit results
- Management review outputs
- Emerging threats
- Lessons learned from incidents

7. Communication and Awareness

The policy is communicated across the organisation through:

- Internal governance platforms
- Employee onboarding programs
- Regular training and awareness sessions

All personnel are required to:

- Acknowledge the policy
- Confirm understanding
- Comply with its requirements

This ensures organisation-wide awareness and accountability.

8. Continual Improvement Commitment

Cyberinfiniti Ltd is committed to maintaining a dynamic and evolving Information Security Management System that adapts to:

- Business growth and operational changes
- Technological advancements
- Regulatory developments
- Emerging cyber threats

This commitment ensures that information security remains resilient, effective, and aligned with industry best practices, particularly ISO/IEC 27002:2022.

Conclusion

The Information Security Policy provides a comprehensive governance framework that aligns strategic leadership, operational controls, and regulatory compliance. By defining executive accountability, measurable objectives, mandatory compliance, Cyberinfiniti Ltd ensures the confidentiality, integrity, and availability of information assets. This policy strengthens client trust, enables audit readiness, and supports a proactive and resilient cybersecurity posture, forming the foundation for continuous improvement and organizational security excellence.

5.2 Information Classification Policy

Below is the approved Information Classification policy of Cyberinfiniti Ltd

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Information Classification Policy
Document ID	CIL-ISMS-IC-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5
Control Reference/Sub-Domain	5.12, 5.13, 5.15, 5.34
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer(s)	Legal /Data Protection Officer,Risk & Compliance Officer, Head of IT
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Party Vendor (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____

For: Cyberinfiniti Ltd

Information Classification Policy

1. PURPOSE

This Agreement establishes:

- A formal information classification scheme (ISO 5.12)
- Mandatory labelling requirements (ISO 5.13)
- Access control enforcement principles (ISO 5.15)
- Protection of personal and regulated data (ISO 5.34)

The objective is to ensure:

- Confidentiality of client and company information
- Integrity of security intelligence and VAPT reports
- Availability of critical business information
- Regulatory compliance
- Structured and accountable information handling

2. SCOPE

This Agreement applies to:

- All employees, contractors, interns, consultants
- Third parties accessing company systems
- All forms of information including:
    - Digital data
    - Physical documents
    - Cloud-hosted data
    - AI-generated outputs
    - Security intelligence
    - Archived records

It applies across the full information lifecycle:

· Creation, Classification, Storage, Transmission, Usage, Archiving, Disposal

3. ISO/IEC 27002:2022 CONTROL ALIGNMENT

ISO Control	Domain	Alignment Description
5.12	Organizational Controls	Establishes formal classification levels

5.13	Organizational Controls	Defines mandatory labelling requirements
5.15	Organizational Controls	Enforces role-based and least privilege access
5.34	Organizational Controls	Protects personal and regulated data

4.INFORMATION CLASSIFICATION FRAMEWORK

All information must be classified into one of the following categories:

4.1 Public

Information approved for public disclosure.

Examples:

- Published security reports
- Marketing materials
- Website content

4.2 Internal

Information intended for internal operational use only.

Examples:

- Internal procedures
- Training materials
- Internal communications

Access limited to authorized personnel.

4.3 Confidential

Sensitive business or client-related information.

Examples:

- Client contracts
- VAPT findings
- Financial records
- Academy trainee personal data

Minimum Controls:

- Role-based access control
- Encryption in transit and at rest
- NDA requirement
- Secure storage in approved systems

4.4 Restricted (Highly Confidential)

Information that could cause severe damage if disclosed.

Examples:

- Exploit details from penetration testing
- Security architecture diagrams
- Privileged credentials
- Incident response forensic evidence
- AI backend scan data

Mandatory Controls:

- Least privilege access
- Multi-factor authentication
- Continuous monitoring
- CISO approval for external sharing

5. CLASSIFICATION & LABELLING REQUIREMENTS

- Information must be classified at creation.
- Electronic documents must include classification in header/footer.
- Emails containing Confidential or Restricted data must be labelled.
- Physical documents must be clearly marked.
- Data classification must be reviewed periodically.

6. HANDLING & STORAGE CONTROLS

- Confidential and Restricted data must only be stored in approved encrypted repositories.
- Cloud storage must meet security baseline requirements.
- Transmission must use secure encrypted channels.
- Disposal must follow secure deletion or shredding procedures.

7. REGULATORY COMPLIANCE

This Agreement supports compliance with:

- Nigeria Data Protection Act
- Client contractual confidentiality obligations

- ISO/IEC 27001 ISMS requirements

8. ROLES & RESPONSIBILITIES

Role	Responsibility
MD	Executive approval
CISO	Policy owner & oversight
Information Security Manager	Implementation & monitoring
Department Heads	Data classification ownership
DPO	Regulatory compliance oversight
SOC Manager	Monitoring unauthorized access
All Employees	Comply with classification requirements

9. EXCEPTIONS

All exceptions must:

- Be formally documented
- Include risk assessment
- Be approved by the CISO
- Have defined expiration period

10. MONITORING & ENFORCEMENT

- Quarterly access reviews
- Quarterly audit of classified repositories
- SOC monitoring for unauthorized access attempts
- Annual policy review

Violations may result in disciplinary action, contract termination, or legal consequences.

11. TRAINING & AWARENESS

- Mandatory Information Handling Training (onboarding)

- Annual refresher training
- Secure data handling awareness campaigns
- Periodic compliance reminders

12. CONTINUAL IMPROVEMENT

This Agreement shall be reviewed:

- Annually
- After major security incidents
- After regulatory changes
- Following audit findings

Management review outputs shall inform revisions.

13. POLICY ACKNOWLEDGEMENT

All personnel must:

- Review this Agreement
- Acknowledge understanding
- Agree to comply

Acknowledgement shall be recorded via the HR compliance system.

Conclusion

CyberInfiniti Ltd recognizes that, as a cybersecurity leader entrusted with sensitive security intelligence and regulated data, structured information classification is fundamental to maintaining client trust, regulatory compliance, and operational resilience. Cyberinfiniti Ltd's Information Classification Policy establishes a structured and ISO-aligned framework for managing information throughout its lifecycle. By defining classification levels, implementing robust controls, and ensuring alignment with ISO/IEC 27002:2022, the organization protects sensitive data, enhances operational security, supports audit readiness, and fosters a culture of accountability. This policy is a cornerstone of Cyberinfiniti Ltd's commitment to information security, risk mitigation, and trust with clients and partners.

5.3 Identity Management and Access Control Policy

Below is the approved Identity Management and Access Control Policy for Cyberinfiniti Ltd

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Identity Management and Access Control Policy
Document ID	CIL-GRC-IAM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5(Organizational Controls)
Control Reference/Sub-Domain	5.16, 5.17
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer(s)	IAM Specialist, Legal & Compliance Officer
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____

For: Cyberinfiniti Ltd

IDENTITY MANAGEMENT & ACCESS CONTROL POLICY

1. Purpose

This policy establishes governance for the full lifecycle of identities and authentication information within CyberInfiniti Ltd. It ensures that all users and systems are uniquely identified, access rights are appropriately assigned and revoked, and authentication mechanisms are securely managed.

The policy supports protection of information assets, accountability of user activities, and compliance with **ISO/IEC 27002:2022** and the **Nigeria Data Protection Act 2023**, as well as contractual obligations.

2. Organisational Context

CyberInfiniti Ltd operates as a cybersecurity and compliance firm handling sensitive client data, vulnerability findings, and regulatory documentation. Effective Identity and Access Management (IAM) is critical to:

- Prevent unauthorized access to systems and data
- Maintain accountability and traceability of user actions
- Protect the confidentiality, integrity, and availability of information assets

IAM forms a foundational control within the organization's overall security and governance framework.

3. Scope

This policy applies to:

- All employees, contractors, and consultants
- All third-party service providers accessing CyberInfiniti systems
- All identities (human and non-human, including service accounts)
- All forms of authentication information (passwords, PINs, tokens, certificates)

It covers all systems, applications, cloud environments, and platforms managed or operated by the organization.

4. IAM Framework Definition

Identity and Access Management (IAM) is the structured framework governing how identities are created, managed, authenticated, and authorized.

It ensures:

- **Unique Identification:** Every entity has a distinct identity
- **Access Control:** Access is granted based on business need and authorization

- **Lifecycle Management:** Identities are created, updated, and removed in a controlled manner
- **Authentication Security:** Credentials are securely issued and managed
- **CIA Protection:** Confidentiality, integrity, and availability are maintained

5. IAM Objectives

CyberInfiniti Ltd aims to:

- Ensure unique and accountable identities
- Enforce least privilege and role-based access
- Manage identity lifecycle efficiently
- Protect authentication information from compromise
- Maintain audit trails for accountability and investigations
- Achieve regulatory and ISO compliance
- Continuously improve IAM controls against evolving threats

6. Policy Statements

Aligned with ISO/IEC 27002:2022 controls **5.16 (Identity Management)** and **5.17 (Authentication Information)**:

6.1 Governance

Management shall provide oversight, resources, and accountability for IAM implementation and enforcement.

6.2 Identity Lifecycle Management

- All identities must be unique and traceable
- Shared accounts are prohibited unless formally approved
- Non-human identities require controlled ownership and monitoring
- Access must be revoked immediately upon role change or exit

6.3 Authentication Security

- Credentials must be securely generated, transmitted, and stored
- Default credentials must be changed immediately
- Temporary credentials must be changed at first use
- Strong authentication (e.g., MFA) must be enforced

6.4 Access Control

- Access rights must follow least privilege and role-based principles
- Access must be formally approved and periodically reviewed

6.5 Compliance

IAM practices must align with regulatory, contractual, and ISO requirements.

6.6 Auditability

All identity and authentication activities must be logged and retained for monitoring, investigation, and audit purposes.

6.7 Continual Improvement

IAM controls shall be continuously improved based on audits, incidents, risk assessments, and regulatory changes.

6.8 Exception Management

Exceptions must be risk-assessed, documented, approved by the CISO, and periodically reviewed.

7. Roles & Responsibilities

Key responsibilities include:

- **Managing Director:** Executive oversight and policy approval
- **CISO:** Policy ownership, strategy, and compliance assurance
- **GRC Manager:** Policy development, monitoring, and audit coordination
- **SOC Manager:** Operational enforcement and incident monitoring
- **IAM Specialist:** Identity lifecycle and access management
- **IT Operations Lead:** Authentication systems and privileged access control
- **System Owners:** Access approval and periodic validation
- **All Employees:** Compliance and protection of credentials
- **Third Parties:** Adherence to IAM requirements

8. Monitoring, Compliance & Enforcement

Compliance is ensured through:

- Periodic access reviews and privilege validation
- Monitoring of privileged and high-risk accounts
- Authentication and credential audits
- Identity lifecycle audits
- Incident tracking (e.g., unauthorized access, credential compromise)
- Risk assessments and executive reporting

Non-compliance may result in disciplinary action, contract termination, or legal consequences.

9. Communication & Awareness

This policy is:

- Published on internal platforms and accessible to all personnel
- Communicated during onboarding and reinforced annually
- Supported by IAM awareness training (e.g., password security, phishing risks)
- Subject to mandatory annual acknowledgement

10. Policy Review & Continual Improvement

This policy is reviewed:

- Annually
- After major IAM incidents
- Following regulatory or technological changes
- Based on audit findings and management reviews

Reviews consider access controls, identity lifecycle processes, authentication mechanisms, emerging threats, and lessons learned.

CyberInfiniti Ltd is committed to continuously strengthening IAM practices to address evolving cybersecurity risks and business needs.

11. ALIGNMENT WITH ISO/IEC 27002:2022

Requirement	Covered in Section
Management approval	Document Control & Approval
Defined IAM objectives	Section 5
Assignment of IAM roles	Section 7
Commitment to IAM compliance	Section 6
Identity lifecycle management	Section 6.2
Authentication information management	Section 6.3
Access rights provisioning & revocation	Section 6.4, Section 8
Records and auditability	Section 6.6, Section 10
Continual improvement	Section 6.7, Section 10

Review at planned intervals	Section 8
Communication & acknowledgement	Section 9

Conclusion

CyberInfiniti Ltd recognizes Identity and Access Management as a critical security control for protecting systems, data, and client trust. By enforcing a structured Identity and Access Management framework, Cyberinfiniti Ltd safeguards its information assets, minimizes the risk of privilege abuse, and ensures accountability across all system interactions. Alignment with **ISO/IEC 27002:2022** ensures consistent governance, audit readiness, and effective mitigation of insider threats and unauthorized access, thereby supporting the organization's strategic objective of maintaining a secure and compliant operational environment.

5.4 Privileged Account Management Policy

Below is the approved Privileged Access Management Policy for Cyberinfiniti Ltd.

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Privileged Access Management Policy
Document ID	CIL-GRC-PAM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 – 8 (Technological Controls)
Control Reference/Sub-Domain	8.2
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer(s)	IAM Specialist, Legal &Compliance Officer
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

Privileged Access Management (PAM) Policy

1. Purpose

The purpose of this policy is to ensure that privileged access rights are strictly controlled, granted only when necessary, and regularly reviewed. The policy minimizes the risk of unauthorized access, misuse, or compromise of critical systems and sensitive information. It enforces:

- Least privilege access
- Accountability through monitoring and logging
- Secure management of elevated credentials

Standards Alignment: ISO/IEC 27002:2022 (Control 8.2), NIST SP 800-53, NIST SP 800-171, CIS Critical Security Controls, COBIT 2019.

2. Scope

This policy applies to:

- Employees, contractors, and consultants with privileged access
- Third-party service providers with elevated access
- All privileged accounts across SOC tools, cloud environments, GRC systems, servers, databases, endpoints, network devices, and security appliances

It governs the **request, approval, provisioning, monitoring, review, revocation, and auditing** of privileged access rights.

3. Key Definitions

- **Privileged Access:** Elevated permissions beyond standard users.
- **Privileged Account:** Admin/root/domain/security tool accounts.
- **Least Privilege:** Access limited to what is strictly necessary.
- **PAM:** Framework controlling and monitoring privileged accounts.
- **MFA:** Multi-Factor Authentication to secure elevated accounts.
- **Segregation of Duties (SoD):** Dividing responsibilities to prevent conflicts.

4. Objectives

- Grant privileged access on a need-to-know, least privilege basis.
- Protect sensitive client environments and systems.
- Define clear processes for access request, approval, monitoring, and revocation.
- Enhance accountability via logging and audits.
- Support regulatory and contractual compliance.

5. Policy Framework

Privileged Account Lifecycle

- **Identification & Classification:** Central inventory; classified as System/Admin, Application, Cloud, Security Tool, Emergency accounts.
- **Request & Approval:** Formal ticketing, documented justification, line manager & system owner approval, time-bound access for projects.
- **Provisioning Standards:** Enforce **least privilege**, **MFA**, unique IDs, secure vaults, complex passwords.
- **Usage Controls:** Privileged accounts only for authorized tasks; monitored sessions; high-risk activity alerts.
- **Monitoring & Logging:** Central logging, alerts for failed logins, privilege escalation, unauthorized changes; logs retained per retention policy.
- **Review & Recertification:** Access reviewed every 90 days or on role change; independent audit every 6 months.
- **Revocation & De-provisioning:** Immediate removal on termination or role change; emergency accounts reviewed post-use.

6. Incident Handling

- Suspected misuse escalated to SOC.
- Investigation follows Incident Response procedures.
- Client notifications aligned with contractual obligations.

7. Compliance & Enforcement

Non-compliance may result in:

- Disciplinary action
- Contractual penalties
- Legal consequences

Exceptions:

- Documented and justified
- Risk-assessed by Information Security Manager
- Approved by Executive Management

8. Roles & Responsibilities

- **Managing Director (MD):** Provides executive oversight, approves PAM policy and critical privileged access assignments & ensures organizational commitment and resource allocation.
- **Chief Information Security Officer (CISO):** Owns the PAM policy, defines strategic direction for privileged access management, approves privileged account provisioning

and emergency access &Oversees compliance with ISO 27002, NIST, and organizational standards

- **System Owners / Heads of Departments:** Approve privileged access requests for their systems, Validate business justification for elevated access, Conduct periodic access reviews & ensure timely revocation of privileges when roles change.
- **SOC Team:** Monitor privileged account usage in real-time, detect anomalies, privilege escalation attempts, and unauthorized activities & generate alerts and report incidents to CISO and management.
- **GRC Team:** Conduct independent audits of privileged accounts, review access recertification and compliance & Support reporting to executive management
- **IAM / IT Operations Team:** Provision and de-provision privileged accounts, enforce multi-factor authentication and least privilege. Securely store credentials using approved vaults & ensure privileged accounts are unique and not shared
- **All Employees / Contractors with Privileged Access:** Use privileged accounts only for authorized tasks, comply with PAM procedures, policies, and monitoring requirements & report any suspected misuse or security incidents immediately.

9. Key Compliance Metrics

- Privileged access inventory completeness
- Quarterly access recertification
- Audit findings and remediation
- Incident response and investigation reports
- MFA adoption rate

10. Continual Improvement

Cyberinfiniti Ltd commits to continuously evolving PAM to address:

- **Business growth:** Scaling for new systems and users
- **Technological changes:** MFA, passwordless solutions, secure vaults
- **Regulatory updates:** NDPA 2023, ISO 27002:2022 compliance
- **Threat evolution:** Mitigating credential theft, insider misuse, and lateral movement

Conclusion

Cyberinfiniti Ltd recognizes that **Privileged Access Management** is critical to safeguarding sensitive client environments, maintaining regulatory compliance, and ensuring operational continuity. By enforcing a structured PAM framework, Cyberinfiniti Ltd safeguards critical systems, client environments, and sensitive information from unauthorized access and misuse. Alignment with **ISO/IEC 27002:2022 Control 8.2** ensures privileged accounts are auditable, monitored, and managed Continuous improvement of PAM processes ensures resilience against evolving cyber threats, supports business growth, and reinforces trust with clients and stakeholders. according to industry best practices, strengthening both security posture and regulatory compliance.

5.5 Artificial Intelligence Governance Policy

Below is the AI Governance Policy for Cyberinifinti Ltd

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Artificial Intelligence Governance Policy
Document ID	CIL-GRC-AI-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5 (Organizational Controls)
Control Reference/Sub-Domain	5.1, 5.7, 5.10, 5.37, 6.3
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Manager
Reviewer(s)	Head of Security Engineering, Legal & Compliance Officer, Data Protection Officer, Head of IT Operations
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

Artificial Intelligence (AI) Policy

1. Purpose

This policy establishes requirements for the secure, ethical, and compliant use of Artificial Intelligence (AI) systems within the organization, supporting risk management and regulatory obligations in line with ISO/IEC 27001 and ISO/IEC 27002:2022.

2. Scope

Applies to all employees, contractors, and third parties using AI tools, models, or services in business operations, including client-facing and internal systems.

3. Roles and Responsibilities

Role	Responsibility
CEO/MD	Policy approval
CISO	Policy ownership & oversight
AI Governance Lead: Head of Security Engineering	Implementation
SOC Manager	Monitoring
DPO	Compliance
Security Engineers	Technical controls
Employees	Compliance

4. Policy Statements

4.1 Acceptable Use

- Only approved AI tools shall be used
- Can be used for documentation drafting
- Threat intelligence summarization using AI is allowed

- Outputs must be reviewed before use in decision-making
- AI usage must be disclosed where required

4.1.1 Prohibited Use

- AI must not be used to process sensitive/client data without authorization
- Using AI without human oversight in critical decisions
- Bypassing security controls using personal AI accounts
- Generating malicious code outside authorized testing

4.2 Risk Management

- AI systems shall undergo risk assessments before deployment
- High-risk AI use cases require formal approval

4.3 Data Protection & Privacy

- No confidential or regulated data shall be input into AI tools without safeguards
- AI usage must comply with applicable data protection laws

4.4 Security Requirements

- AI systems must follow secure configuration and access control practices
- Integration with enterprise systems must be authorized

4.5 Third-Party AI

- Vendors must undergo due diligence and security assessment
- Contracts must include security and data protection clauses

4.6 Monitoring & Compliance

- AI usage shall be logged and periodically reviewed
- Violations may result in disciplinary action

5. Compliance & Alignment

This policy aligns with:

- Nigeria Data Protection Act (NDPA 2023)
- GDPR (where applicable)
- Client contractual obligations
- ISO/IEC 27001 requirements

6. Review

- Reviewed annually or upon significant change

7. Enforcement

Non-compliance may lead to disciplinary action, including access revocation or termination

Conclusion

CyberInfiniti Ltd recognizes that Artificial Intelligence is a critical enabler in cybersecurity operations but introduces significant risk if not governed effectively. This policy establishes a secure, ethical, and resilient AI governance framework aligned with ISO standards and global best practices.Through this AI Governance Policy, Cyberinfiniti Ltd establishes formal authority, controls, and oversight over AI tools and automation usage.

By enforcing approval processes, data restrictions, output validation, and risk assessments, and aligning with **ISO/IEC 27002:2022 Organizational Controls (Domain 5)**, the organization mitigates security, operational, and compliance risks. This structured approach enables responsible innovation, operational resilience, and readiness for future regulatory expectations

5.6 Incident Management Policy

Below is the approved Incident Management Policy for Cyberinfiniti Ltd

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Incident Management Policy
Document ID	CIL-GRC-IM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5 (Organizational Controls)
Control Reference/Sub-Domain	5.24, 5.28
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	SOC Manager
Reviewer(s)	GRC Manager, Legal & Compliance Officer, Head of IT Operations
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

Incident Management Policy

1. Purpose

The purpose of this policy is to establish a structured and coordinated approach for identifying, assessing, responding to, and learning from information security incidents affecting Cyberinfiniti Ltd. The policy ensures incidents are managed in a timely, consistent, and legally compliant manner, in alignment with:

- ISO/IEC 27002:2022 (Controls 5.24 – 5.28)
- Nigeria Data Protection Act (NDPA) 2023
- Client contractual breach notification obligations
- Business continuity requirements

2. Organizational Context

Cyberinfiniti Ltd provides SOC operations, penetration testing, cloud security advisory, GRC consulting, and security training. Handling sensitive client security data, vulnerability findings, threat intelligence, compliance documentation, and personal data under NDPA 2023 necessitates a structured incident response framework. Ineffective management could result in regulatory penalties, contractual breaches, financial loss, reputational harm, and loss of client trust.

3. Scope

Applies to:

- All employees, contractors, SOC personnel, and third-party service providers
- All systems, networks, endpoints, and cloud services
- All client-managed environments

4. Definitions

- **Security Incident:** Any confirmed event compromising confidentiality, integrity, or availability of information, violating policies, disrupting operations, or causing unauthorized access, disclosure, alteration, or destruction.
- **Security Event:** Becomes an incident when it poses credible risk or confirmed impact.

5. Incident Management Objectives

- Detect and respond to incidents quickly to minimize disruption and financial impact.
- Protect client and organizational data while meeting regulatory and contractual obligations.
- Preserve evidence and continually improve response processes through lessons learned.

6. Incident Management Framework

6.1 Planning and Preparation

- Establish an Incident Response Team (IRT) with documented roles and escalation paths.
- Maintain incident playbooks for common threat scenarios.
- Train all employees on reporting procedures.

6.2 Detection and Reporting

- Sources: SIEM alerts, EDR/XDR, user reports, threat intelligence, client notifications.
- All suspected incidents must be reported to SOC within 30 minutes.

6.3 Assessment and Classification

- Assess incidents based on business impact, data sensitivity, regulatory exposure, and system criticality.
- Severity levels: Critical, High, Medium, Low.
- Escalation follows the approved matrix.

6.4 Response and Containment

- Actions include endpoint isolation, account suspension, network segmentation, and IP blocking.
- All actions documented in the Incident Register.

6.5 Eradication and Recovery

- Address root causes and vulnerabilities.
- Restore systems from secure backups.
- Validate integrity before returning systems to production.

6.6 Lessons Learned

- Conduct post-incident review within 10 business days.
- Include root cause analysis, control weaknesses, impact assessment, and corrective actions.

6.7 Evidence Collection

- Preserve evidence forensically, with timestamps, access control, and secure storage.
- Maintain chain of custody documentation.

7. Roles and Responsibilities

- **Managing Director:** Executive oversight

- **CISO:** Strategic direction and escalation authority
- **SOC Manager:** Incident coordination
- **Security Analyst:** Detection and investigation
- **GRC Manager:** Regulatory reporting & compliance
- **IT Operations Lead:** Containment and recovery
- **All Employees:** Prompt incident reporting

8. Policy Review and Maintenance

- Reviewed annually, after major incidents, regulatory changes, or operational changes.

9. Communication and Awareness

- Published on internal governance portal
- Communicated to staff and included in onboarding
- Reinforced during annual awareness programs

10. Enforcement

Non-compliance may result in disciplinary measures, contract termination, or legal action.

Conclusion

Cyberinfiniti Ltd is committed to proactive and structured incident management to minimize operational, regulatory, and reputational risks. By implementing a lifecycle approach i.e planning, detection, assessment, response, recovery, and lessons learned, the organization ensures rapid containment of threats, protection of sensitive data, and continual improvement of its security posture in alignment with ISO/IEC 27002:2022 and NDPA 2023.

5.7 Clear Desk & Clear Screen Policy

Below is the approved Clear Desk & Clear Screen Policy for Cyberinifinti Ltd.

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Clear Desk & Clear Screen Policy
Document ID	CIL-GRC-CDCS-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 7(Physical Controls)
Control Reference/Sub-Domain	7.7
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	GRC Lead
Reviewer(s)	Legal & Compliance Officer, Data Protection Officer, Head of IT, HR Manager
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

CLEAR DESK & CLEAR SCREEN POLICY

1. Purpose

The purpose of this policy is to prevent unauthorized access, disclosure, or loss of sensitive information by enforcing proper handling of physical and digital information assets within CyberInfiniti Ltd. This policy ensures that confidential information is not exposed through unattended desks, unsecured screens, or improperly stored materials, thereby protecting the confidentiality, integrity, and availability of organizational and client data.

2. Scope

This policy applies to:

- All employees of CyberInfiniti Ltd
- Trainees and interns (where applicable)
- Third-party vendors, partners, and consultants
- All business locations, including remote work environments
- All systems, devices, and physical workspaces used to process or store company information

3. Policy Requirements

3.1 Clear Desk Requirements

All personnel must ensure that sensitive information is properly secured when leaving their workspace (temporarily or at end of day):

- Confidential documents must not be left unattended on desks
- Physical documents must be securely stored in locked cabinets
- Printed materials must be handled and stored securely at all times
- Disposal of sensitive documents must be done using approved shredding methods
- Removable storage devices (e.g., USB drives) must be securely stored when not in use
- Meeting rooms must be cleared after use:
    - Whiteboards and display materials must be erased
    - Documents must not be left behind

3.2 Clear Screen Requirements

All users must ensure protection of information displayed on screens:

- Devices must automatically lock after a maximum of 5 minutes of inactivity
- All systems must have auto-lock enabled
- Secure screen filters should be used where necessary (e.g., open/public environments)
- User credentials must not be shared under any circumstances (zero trust principle)

- Multi-factor authentication (MFA) must be enabled for all access to CyberInfiniti systems
- Users must log out of systems at the end of each work session
- Screens displaying sensitive or client information must not be visible in public or unsecured areas
- Devices must be locked whenever left unattended

4. Standards & Regulatory Alignment

ISO Alignment

This policy aligns with:

- **ISO/IEC 27002:2022 – Control 7.7 (Clear Desk and Clear Screen)**
  Ensures protection of physical documents, removable media, and on-screen information.

Regulatory Requirements

This policy supports compliance with:

- **Nigeria Data Protection Act 2023 (NDPA):** Requires protection of personal data against unauthorized access or disclosure
- **General Data Protection Regulation (GDPR):** Mandates safeguarding of personal data, including prevention of visual or physical exposure

Industry Standards

- **PCI DSS:** Requires securing physical and digital environments handling cardholder data

5. Monitoring & Compliance

Compliance with this policy will be enforced through:

- Bi-annual internal audits
- Weekly unannounced desk inspections (HQ)
- Monthly compliance checks across locations
- Monitoring of Security Operations Center (SOC) logs for potential violations

6. Enforcement & Sanctions

Non-compliance with this policy may result in:

- Disciplinary action

- Formal warnings
- Revocation of system access
- Termination of employment or contract (for severe or repeated violations)

7. Review & Continuous Improvement

This policy shall be reviewed:

- Annually
- After security incidents involving data exposure
- Following regulatory or operational changes

Continuous improvement will be driven by audit findings, incident reports, and evolving security risks.

8. Roles & Responsibilities

Key responsibilities include:

- **Managing Director:** Executive oversight and policy approval
- **CISO:** Policy ownership, strategy, and compliance assurance
- **GRC Manager:** Policy development, monitoring, and audit coordination
- **SOC Manager:** Operational enforcement and incident monitoring
- **IT Operations Lead:** Implements technical controls such as auto-lock configurations, MFA enforcement, and secure screen policies across systems and devices.
- **Department Heads:** Ensure team compliance with clear desk and clear screen requirements; enforce adherence during daily operations.
- **All Employees:** Comply with policy requirements, secure physical and digital information, and report any observed violations or risks immediately.
- **Third Parties:** Adhere to CyberInfiniti's clear desk and clear screen requirements when accessing company facilities or systems.

Conclusion

The Clear Desk and Clear Screen (CDCS) Policy establishes CyberInfiniti's approach to safeguarding sensitive information by minimizing the risk of unauthorized access, loss, or exposure in both physical and digital work environments. This policy requires all personnel to ensure that confidential and sensitive information,whether in paper or electronic form is properly secured when not in use. Workspaces must be kept free of exposed documents, removable media, and written credentials, while computer screens and devices must be locked or secured when unattended. These practices reduce the likelihood of data breaches, insider threats, and accidental disclosures, especially in shared or hybrid work environments.

Ultimately, this policy reinforces a culture of security awareness and accountability, ensuring that information assets remain protected at all times.

5.8 Third-Party & Vendor Risk Management Policy

Below is the approved Third Party & Vendor Management Policy for Cyberinfiniti Ltd

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Third Party & Vendor Management Policy
Document ID	CIL-ISMS-TPVM-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5(Organizational Controls) & 8(Technological Controls)
Control Reference/Sub-Domain	5.19, 5.20, 5.21, 5.22, 5.23, 8.8, 8.9, 8.32
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	Security Engineering Lead
Reviewer(s)	Legal & Compliance Officer, Data Protection Officer, SOC Manager, DevSecOps Lead, IT Infrastructure Manager
Classification	Confidential - Internal Use Only
Distribution	All employees, Contractors, Third Parties(where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

Third Party &Vendor Management Policy

1. Organisational Context

Given the nature of our operations, CyberInfiniti Ltd processes sensitive assets including client data, threat intelligence, security configurations, cloud-hosted applications, and personal data governed by the **Nigeria Data Protection Act 2023**.

Third-party relationships introduce risks such as unauthorized access, data breaches, service disruption, and regulatory non-compliance. This policy establishes a structured framework to ensure that supplier engagements do not compromise the confidentiality, integrity, and availability of information assets, while maintaining client trust and regulatory alignment.

2. Purpose

The purpose of this policy is to ensure that all third-party and vendor relationships are governed in a secure, risk-based, and compliant manner.

CyberInfiniti Ltd is committed to:

- Ensuring suppliers meet defined security and compliance standards
- Conducting due diligence prior to onboarding vendors
- Enforcing contractual security and data protection obligations
- Monitoring supplier performance and security posture continuously
- Managing supplier risks throughout the lifecycle

This policy aligns with **ISO/IEC 27002:2022** controls 5.19–5.23 on information security in supplier relationships.

3. Scope

This policy applies to:

- All third-party vendors, suppliers, contractors, consultants, and partners
- All employees and departments managing supplier relationships
- All systems, services, and data accessed or managed by suppliers

Vendors with no access to sensitive systems or data (e.g., facilities or construction vendors) are generally out of scope unless specified otherwise.

4. Governance & Roles

Supplier security is governed through clearly defined roles:

- **Executive Management:** Approves high-risk engagements and ensures oversight

- **CISO:** Owns the policy, conducts risk assessments, and ensures compliance
- **Procurement Team:** Embeds security requirements into contracts
- **IT/Technical Team:** Manages access and validates technical controls
- **Legal & Compliance:** Ensures regulatory and contractual alignment
- **Contract Owners:** Manage supplier relationships and performance
- **Suppliers:** Must comply with all CyberInfiniti security requirements

This structure ensures accountability and consistent enforcement across the supplier lifecycle.

5. Vendor Risk Management Framework

Suppliers are classified based on risk exposure:

- **Critical:** Direct access to sensitive data or production systems (reviewed quarterly)
- **High:** Access to regulated or non-production systems (bi-annual review)
- **Medium:** Limited or indirect access (annual review)
- **Low:** No system or sensitive data access (light annual review)

Risk classification determines the level of due diligence, monitoring, and control enforcement applied.

6. Policy Requirements

6.1 Supplier Due Diligence

All suppliers must undergo security assessment prior to onboarding. High-risk vendors must demonstrate strong security controls (e.g., ISO certifications or audit reports).

6.2 Contractual Security Controls

Supplier agreements must include:

- Confidentiality and data protection clauses
- Incident reporting obligations
- Defined SLAs and security controls
- Right-to-audit provisions

6.3 Access Management

- Supplier access must follow least privilege principles
- Access must be reviewed regularly
- Access must be revoked immediately upon termination

6.4 Monitoring & Review

- Supplier performance and compliance are reviewed periodically
- Changes in supplier services must undergo security impact assessment

6.5 Incident Management

Suppliers must:

- Report incidents within 24 hours
- Support investigations and remediation
- Provide root cause analysis

6.6 Supplier Termination

Upon termination:

- All access is revoked
- Data must be returned or securely deleted
- Exit procedures must be formally completed

7. Compliance & Regulatory Alignment

This policy supports compliance with:

- **General Data Protection Regulation (GDPR) / NDPR** – Protection of personal data
- **ISO/IEC 27001 & ISO/IEC 27002** – Supplier security governance
- **NIST Cybersecurity Framework** – Supply chain risk management
- **CIS Controls v8** – Service provider management

8. Monitoring, Enforcement & Metrics

Compliance is enforced through:

- Supplier audits and security assessments
- Access reviews and vendor monitoring
- Tracking of incidents and SLA adherence
- Maintenance of a vendor risk register

Key metrics include:

- Supplier audit results
- Incident frequency and response times
- SLA compliance rates

- Risk rating updates

Non-compliance may result in:

- Access revocation
- Contract suspension or termination
- Disciplinary or legal action

9. Exceptions & Governance Control

Exceptions must:

- Be formally documented
- Undergo risk assessment
- Receive executive approval
- Include defined validity and review timelines

10. Continuous Improvement

CyberInfiniti Ltd is committed to continuously improving supplier security governance through:

- Periodic audits and reviews
- Lessons learned from incidents
- Regulatory updates
- Evolving threat intelligence

Conclusion

CyberInfiniti Ltd recognizes that third-party risk is a critical component of cybersecurity governance. Through structured supplier management aligned with ISO standards and global best practices, the organization ensures that all vendor relationships support secure, resilient, and compliant operations. The policy ensures that Cyberinfiniti Ltd maintains a robust, standardized, and compliant approach to third-party and vendor management, minimizing exposure to external threats and aligning supplier relationships with organizational security objectives.

5.9 Vulnerability Management & Secure Testing Policy

Below is the approved Vulnerability Management & Secure Testing Policy for Cyberinfiniti Ltd.

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Vulnerability Management & Secure Testing Policy
Document ID	CIL-GRC-VMSTP-2026-001
Version	1.0
Effective Date	18 February 2026
Review Date	18 February 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 8 (Technological Controls)
Control Reference/Sub-Domain	8.8, 8.9, 8.32
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	Head of Security Engineering
Reviewer(s)	Legal & Compliance Officer, Data Protection Officer, Head of Security Operations
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

Vulnerability Management & Secure Testing Policy Summary

1. Overview and Organisational Context

CyberInfiniti Ltd In the course of its operations handles highly sensitive assets, such as client data, threat intelligence, security configurations, cloud-hosted systems, and personal data regulated under Nigeria Data Protection Act 2023. Given this risk exposure, the organisation must maintain a robust vulnerability management and secure testing framework to protect the confidentiality, integrity, and availability of its systems and data. Failure to effectively manage vulnerabilities could lead to regulatory breaches, financial loss, reputational damage, and loss of client trust.

This policy establishes a structured governance framework aligned with ISO/IEC 27002:2022 controls 8.8 (Technical Vulnerability Management), 8.9 (Configuration Management), and 8.32 (Change Management).

2. Purpose and Scope

The purpose of this policy is to define a **risk-based approach** to:

- Identifying and assessing vulnerabilities
- Prioritising and remediating risks
- Maintaining secure system configurations
- Conducting secure testing activities
- Integrating remediation into change management processes

The policy ensures protection of information assets, reduction of exploit risks, and compliance with regulatory and contractual obligations.

It applies across the organisation's entire technology landscape, including: Infrastructure (networks, endpoints, SOC systems, cloud environments), Applications (internal systems, client-facing platforms, APIs, DevOps pipelines)&Third-party components (SaaS services, vendors, open-source libraries)

3. Governance and Policy Requirements

CyberInfiniti Ltd commits to:

- Identifying vulnerabilities in a timely manner
- Assessing risk exposure using defined criteria
- Remediating vulnerabilities within established service-level timelines
- Maintaining secure configuration baselines
- Conducting periodic and risk-based testing
- Tracking and auditing all vulnerability management activities

This ensures accountability, traceability, and alignment with international standards such as ISO/IEC 27002:2022.

4. Vulnerability Management Framework

4.1 Identification and Scanning

The organisation adopts a proactive approach to vulnerability identification through:

- Vendor security advisories
- Threat intelligence feeds
- Automated vulnerability scanning
- Open-source dependency analysis
- Configuration compliance checks

Scanning is conducted regularly based on system criticality, with frequencies ranging from **monthly (internal systems, cloud)** to **per release (applications)** and **quarterly (external systems)**.

4.2 Risk Classification and Remediation

Vulnerabilities are prioritised based on:

- CVSS scores
- Exploit availability
- Asset criticality
- Data sensitivity
- Business impact

Defined remediation timelines include:

- Critical: within 7 days
- High: within 14 days
- Medium: within 30 days
- Low: risk acceptance or scheduled remediation

4.3 Tracking and Reporting

All vulnerabilities are:

- Logged in a central vulnerability register
- Assigned to responsible owners
- Tracked through to resolution
- Verified through re-scanning

Monthly reviews are conducted by the CISO to ensure oversight and accountability.

5. Configuration and Secure Testing Controls

5.1 Configuration Management

Secure configuration baselines are maintained across systems, including operating systems, network devices, cloud environments, and databases. These baselines are aligned with industry standards such as CIS benchmarks, vendor hardening guides, and security best practices.

Key controls include:

- Prohibition of unauthorized configuration changes
- Quarterly baseline reviews
- Documentation and approval of any deviations

5.2 Secure Testing Practices

CyberInfiniti implements multiple layers of security testing:

- **Penetration Testing**: Conducted annually and after major system changes
- **Secure Code Testing**: Includes SAST, DAST, dependency scanning, and secrets detection
- **Advanced Testing**: Red teaming and adversarial simulations for high-risk systems

These practices ensure early detection of weaknesses and validation of security controls.

6. Change Management and Exception Handling

All remediation activities must follow formal change management processes aligned with ISO/IEC 27002:2022 control 8.32. This includes:

- Documented change requests
- Pre-deployment testing
- Approval from the Change Advisory Board (CAB)
- Defined rollback procedures

Emergency changes are permitted but must be documented retrospectively.

Where remediation cannot be completed within defined timelines:

- A formal risk assessment must be conducted
- Compensating controls must be implemented
- Risk acceptance must be approved by the CISO and relevant stakeholders
- Exceptions must include review timelines and expiration dates

7. Compliance, Monitoring, and Reporting

This policy supports compliance with:

- Nigeria Data Protection Act 2023 (data protection)
- ISO/IEC 27001 certification requirements
- Client contractual service-level agreements
- SOC 2 security principles

Compliance is monitored through:

- Monthly vulnerability dashboards
- Quarterly executive risk reports
- Annual penetration testing reports
- Internal audits

Key performance indicators include:

- SLA compliance rates
- Time to remediate vulnerabilities
- Number of open vulnerabilities
- Recurrence rates

8. Roles, Responsibilities, and Incident Integration

Clear accountability is established across roles:

- Executive management provides oversight
- The CISO owns the policy and governance
- Security and DevSecOps teams manage scanning and testing
- IT teams handle patching and infrastructure security
- System owners approve risk acceptance

If a vulnerability is exploited, the **Incident Management Policy** is triggered, followed by root cause analysis and integration of lessons learned into continuous improvement processes.

9. Training, Review, and Continuous Improvement

CyberInfiniti ensures ongoing capability development through:

- Secure coding training
- DevSecOps and testing training
- Configuration management awareness programs

The policy is reviewed:

- Annually
- After major incidents
- Following regulatory or audit changes

All personnel must formally acknowledge the policy and their responsibilities.

Conclusion

This policy establishes a comprehensive, risk-driven approach to vulnerability management and secure testing within CyberInfiniti Ltd. By aligning with ISO/IEC 27002:2022 and regulatory requirements such as Nigeria Data Protection Act 2023, the organisation ensures proactive risk mitigation, operational resilience, and sustained client trust in an evolving cybersecurity landscape. This policy ensures that Cyberinfiniti Ltd maintains a robust, proactive, and ISO-aligned vulnerability management and secure testing program, mitigating technical risks while reinforcing operational integrity and client trust.

5.10 Business Continuity & Disaster Recovery Policy

Below is the approved BC/DR Policy for Cyberinfiniti Ltd.

DOCUMENT CONTROL PAGE

Field	Details
Document Title	Business Continuity & Disaster Recovery Policy
Document ID	CIL-ISMS-BCDR-2026-001
Version	1.0
Effective Date	01 March 2026
Review Date	01 March 2027
Policy Domain	ISO/IEC 27002:2022 –Domain 5&8
Control Reference/Sub-Domain	5.29, 5.30, 8.13
Policy Owner	Chief Information Security Officer (CISO)
Policy Author	IT Operations Lead
Reviewer(s)	Chief Operating Officer, Legal & Compliance Officer, Data Protection Officer, SOC Manager, Head of Cloud Infrastructure, IT Infrastructure Manager
Classification	Confidential - Internal Use Only
Distribution	All Employees, Contractors, Third Parties (where applicable)
Supercedes	New Document

APPROVED BY
Managing Director (CEO)

_____J.O_____
For: Cyberinfiniti Ltd

BUSINESS CONTINUITY & DISASTER RECOVERY POLICY

1. Purpose

This policy defines a governance framework to ensure that critical business operations remain available during disruptions and that ICT systems are resilient, recoverable, and secure.

It ensures:

- Continuity of essential cybersecurity services
- Protection and recoverability of critical data
- Defined and achievable recovery objectives (RTO & RPO)
- Secure and tested backup mechanisms
- Compliance with regulatory and contractual requirements
- Executive involvement in crisis decision-making

2. Scope

This policy applies to all critical operational and technical environments, including:

- SOC operations and monitoring systems
- Incident response and threat intelligence platforms
- Cloud infrastructure environments (Azure, AWS)
- Client-facing portals and reporting systems
- Cybersecurity training platforms
- Internal IT systems supporting operations

It also covers disruption scenarios such as cyber incidents, infrastructure failures, ransomware attacks, cloud region outages, extended power loss, and telecommunications disruptions.

3. Policy Statement

CyberInfiniti Ltd adopts a proactive, risk-based approach to operational resilience. The organization shall:

- Conduct annual Business Impact Analysis (BIA)
- Define Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO)
- Maintain encrypted and geographically separated backups
- Implement documented Disaster Recovery procedures
- Test business continuity and recovery capabilities annually
- Escalate major incidents to executive leadership
- Continuously improve resilience and recovery capabilities

4. Business Impact Analysis (BIA)

A formal BIA is conducted annually to identify critical business functions, determine acceptable downtime thresholds, and assess operational, financial, and reputational impacts.

Critical functions include:

- SOC Monitoring (RTO: 4 hours, RPO: 15 minutes)
- Incident Response Systems (RTO: 6 hours, RPO: 30 minutes)
- Client Reporting Platforms (RTO: 12 hours, RPO: 1 hour)
- Training Platforms and internal systems (lower priority tiers)

These outputs guide recovery prioritization and resource allocation.

5. ICT Readiness & Resilience

Aligned with **ISO/IEC 27002:2022 controls 5.29 and 5.30**, CyberInfiniti ensures ICT readiness through:

- Multi-zone cloud infrastructure deployment
- Redundant internet connectivity for SOC operations
- High-availability security and monitoring architecture
- Secondary communication channels for crisis situations
- Cloud-based Disaster Recovery environments
- Infrastructure-as-Code (IaC) for rapid system restoration

This ensures the organization can maintain or quickly restore operations during disruptions.

6. Backup & Recovery Management

In alignment with **ISO/IEC 27002:2022 control 8.13**, CyberInfiniti implements secure backup practices:

- Daily automated backups and weekly full backups
- Encryption of all backup data
- Storage in geographically separate cloud regions
- Use of immutable backups where supported

Backup reliability is validated through:

- Biannual restoration testing
- Random recovery verification exercises
- Documented evidence of successful recovery

7. Disaster Recovery & Crisis Management

In the event of a disruption:

- Incidents are escalated to the Incident Response Team
- Executive leadership is notified promptly
- The CISO and COO authorize DR activation
- Systems are restored based on business priority
- Clients and stakeholders are informed where required
- Post-incident reviews are conducted to improve resilience

A Crisis Management Team is activated for major incidents, ensuring coordinated response and governance oversight.

8. Testing & Continuous Improvement

CyberInfiniti conducts regular testing to validate resilience capabilities, including:

- Annual BC/DR simulation exercises
- Tabletop and scenario-based drills
- Failover and backup restoration testing
- SOC operational continuity exercises

Performance metrics such as recovery time, backup success rate, and response effectiveness are tracked and reported to executive management.

Lessons learned from incidents, audits, and tests are integrated into continuous improvement initiatives.

9. Regulatory & Contractual Alignment

This policy supports compliance with:

- **Nigeria Data Protection Act 2023** – ensuring availability and protection of personal data
- Client contractual SLAs – maintaining uptime and recovery commitments
- ISO/IEC 27001 certification readiness – supporting Annex A controls
- Industry expectations for cybersecurity service providers

10. Roles & Responsibilities

Key responsibilities include:

- **Managing Director (MD):** Executive oversight

- **Chief Information Security Officer (CISO):** Policy ownership and DR activation authority
- **Chief Operating Officer (COO):** Operational continuity
- **SOC Manager:** SOC resilience execution
- **Cloud Engineering Lead:** Infrastructure recovery
- **IT Manager:** Backup and restoration processes
- **Data Protection Officer (DPO):** Regulatory compliance and breach notification
- **All Staff:** Compliance with BC/DR procedures

11. Monitoring, Compliance & Review

The effectiveness of this policy is monitored through:

- Quarterly resilience reporting to executive leadership
- Annual BC/DR audits
- KPI tracking (RTO performance, backup success, testing completion)

Exceptions must be risk-assessed, formally approved, and time-bound.

The policy is reviewed annually or following major incidents, regulatory changes, or audit findings to ensure ongoing relevance and effectiveness.

Conclusion

CyberInfiniti Ltd recognizes that operational resilience is essential to maintaining client trust, regulatory compliance, and cybersecurity effectiveness. Through structured BC/DR governance aligned with **ISO/IEC 27002:2022**, the organization is committed to ensuring secure, resilient, and continuously available services in the face of evolving disruptions. This BC/DR policy ensures Cyberinfiniti Ltd maintains operational resilience, protecting both internal and client-facing services from disruptions while complying with ISO/IEC 27002:2022 standards.

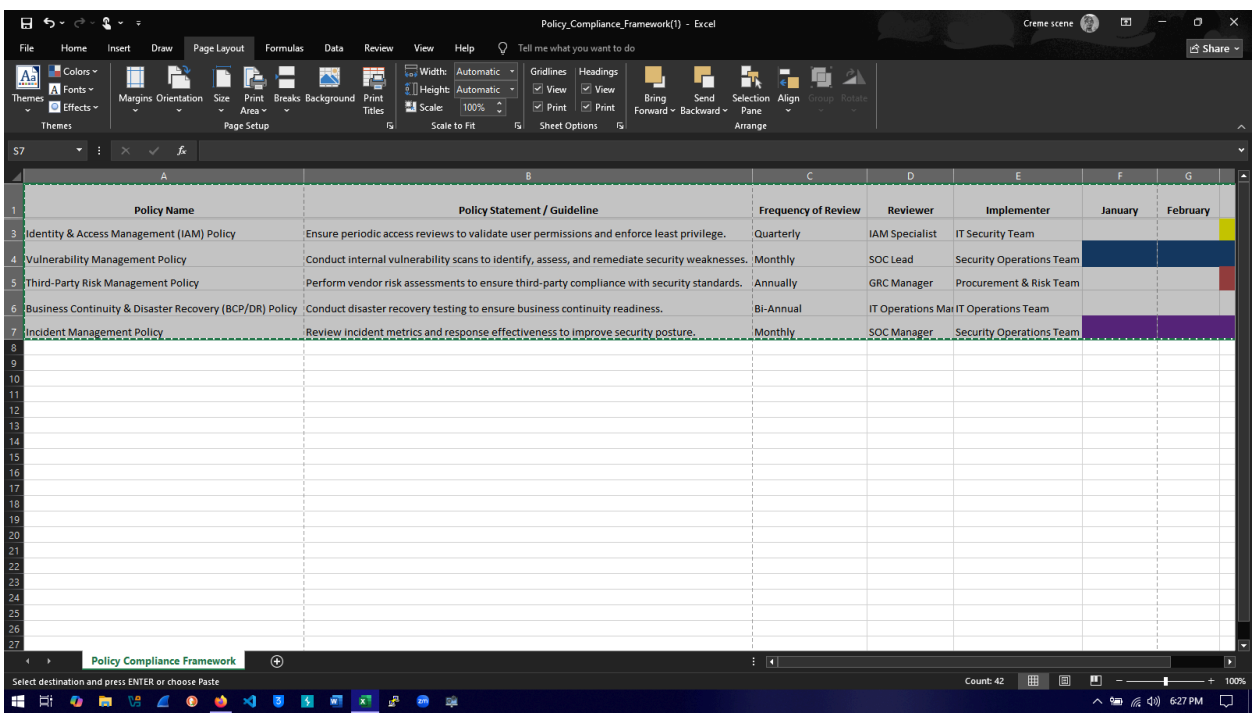
6.0 Pictorial Representation of Developed Policies

Policy	Author (Role)	Owner (Role)	Reviewer	Approver
Information Security Policy	GRC Manager	CISO	Executive Mgmt	Managing Director
Information Classification	GRC Manager	CISO	IT Ops	MD
IAM Policy	GRC Manager	CISO	SOC Manager	MD
Privileged Access Mgmt	IAM Specialist	CISO	Head Sec Eng	MD
AI Governance	GRC Manager	CISO	Legal Officer	MD
Incident Management	SOC Manager	CISO	GRC Manager	MD
Clear Desk Policy	HR Manager	CISO	IT Ops	MD
Third-Party Risk	Legal & Compliance Officer	CISO	GRC Manager	MD
Vulnerability Management	Head Security Engineering	CISO	SOC Manager	MD
Business Continuity	IT Operations Lead	CISO	GRC Manager	MD

7.0 Integrated Compliance & Monitoring Model

A measurable compliance structure was implemented:

Policy Area	Monitoring Method	Frequency	Evidence	Reporting
IAM	Access Review	Quarterly	Access Logs	CISO
Vulnerability	Scan Reports	Monthly	Scan Evidence	CTO
Third-Party	Risk Assessment	Annually	Vendor File	MD
Incident	KPI Dashboard	Monthly	Incident Report	Executive
BCP	DR Test	Bi-Annual	DR Report	Board



Policy Name	Policy Statement / Guideline	Frequency of Review	Reviewer	Implementer	January	February
Identity & Access Management (IAM) Policy	Ensure periodic access reviews to validate user permissions and enforce least privilege.	Quarterly	IAM Specialist	IT Security Team		
Vulnerability Management Policy	Conduct internal vulnerability scans to identify, assess, and remediate security weaknesses.	Monthly	SOC Lead	Security Operations Team		
Third-Party Risk Management Policy	Perform vendor risk assessments to ensure third-party compliance with security standards.	Annually	GRC Manager	Procurement & Risk Team		
Business Continuity & Disaster Recovery (BCP/DR) Policy	Conduct disaster recovery testing to ensure business continuity readiness.	Bi-Annual	IT Operations Mar	IT Operations Team		
Incident Management Policy	Review incident metrics and response effectiveness to improve security posture.	Monthly	SOC Manager	Security Operations Team		

Plate 1.0 Compliance Framework

7.1 Pictorial Representation of Policy Governance Structure

Policy Governance Model

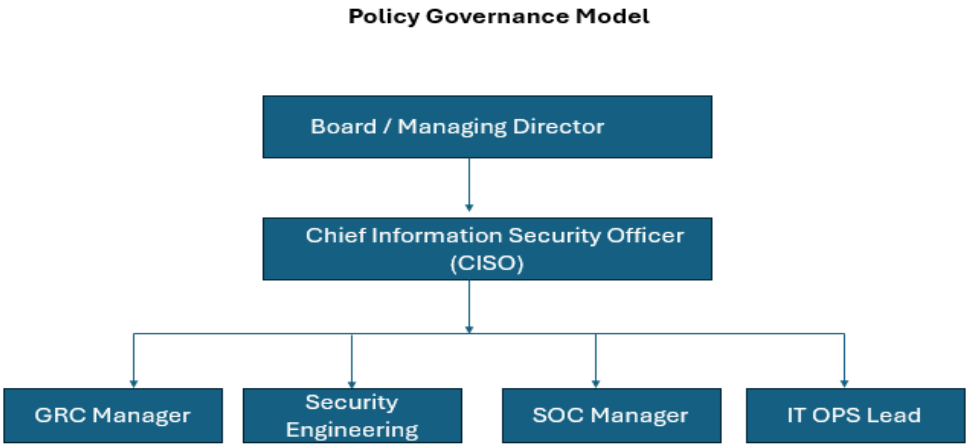


Plate 1.1 Policy Governance Model of the organization

Policy Lifecycle Flow

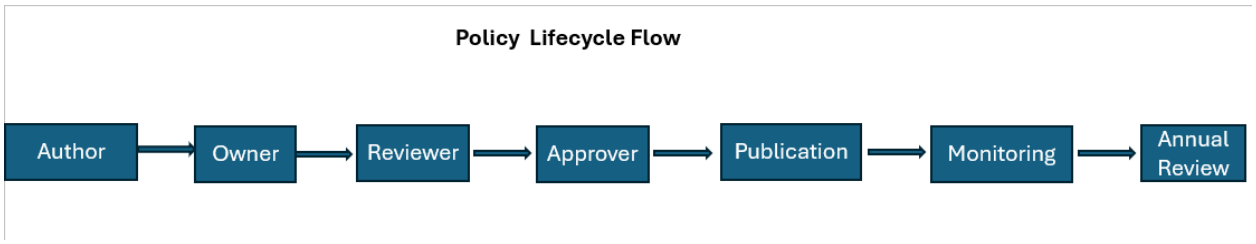


Plate 1.2: Policy lifecycle flow

8.0 Domain, Sub-Domain & Control Mapping (ISO/IEC 27002:2022)

Policy	Domain	Sub-Domain	Control No.
Information Security	Organizational Controls	Information Security Policy	5.1
Information Classification	Organizational Controls	Information Classification	5.12
IAM Policy	Technological Controls	Access Control	8.2
Privileged Access Management	Technological Controls	Privileged Access	8.2
AI Governance	Organizational Controls	Information Security in Projects	5.8
Incident Management	Organizational Controls	Incident Management	5.24–5.28
Clear Desk & Screen	Physical Controls	Clear Desk & Clear Screen	7.7
Third-Party Risk	Organizational Controls	Supplier Relationships	5.19–5.23
Vulnerability Management	Technological Controls	Technical Vulnerability Management	8.8
Business Continuity	Organizational Controls	ICT Readiness for BC	5.30

9.0 NDPA 2023 Regulatory Integration

All implemented policies have been properly aligned with the requirements of the Nigeria Data Protection Act (NDPA) 2023 to ensure lawful, transparent, and accountable processing of personal data across all business operations. This policy framework ensures:

1. **Lawful Processing Governance**: All personal data processing activities are conducted under clearly defined lawful bases, with documented justification and oversight.
2. **Compliance with Data Breach Notification Timelines**: Structured procedures are established to detect, assess, and report personal data breaches in accordance with NDPA regulatory timelines and reporting obligations.
3. **Data minimization principle**: Personal data collected is limited to what is necessary, relevant, and proportionate for clearly defined business purposes and processed strictly on a need-to-know basis.
4. **Vendor Data Protection Clauses**: All third-party agreements include NDPA-compliant Data Processing Agreements (DPAs) with clear accountability for handling data.
5. **Storage and transmission of data subjects' personal data**: Access controls, monitoring are implemented to store data safely and data are to be encrypted at rest and in transit.
6. **Accountability & Documentation**: Evidence of compliance activities is maintained to demonstrate regulatory adherence when required.

By successfully integrating NDPA principles with Cyberinfiniti Ltd's developed policies, there is a significant reduction of regulatory exposure, potential financial penalties, and reputational risk under Nigerian data protection law.

10.0 Executive Risk Insights

The sprint identified strategic risks:

1. **Excessive privileged access without structured reviews**: We have been able to identify that privileged access rights are granted without periodic review or formal approval workflows.

   Risk exposure

   - Unauthorized system changes or data exfiltration
   - Insider threats or misuse of admin rights
   - Increased blast radius in case of credential compromise
2. **Vendor onboarding without due diligence:** Vendors are allowed into our system without proper vetting, background checks and meeting the minimum requirements.

   Risk exposure

   - Supply chain attacks (e.g., compromised vendor access)
   - Regulatory violations due to third-party data mishandling
   - Unauthorized access to sensitive or client data
   - Reputational damage
3. **Unmonitored vulnerability backlog:** Security vulnerabilities are identified but not consistently tracked, prioritized, or remediated within defined timelines.

   Risk exposure

   - Exploitation of known vulnerabilities (most breaches occur here)
   - Increased attack surface and exposure window
   - Weak alignment with secure testing and vulnerability management standards
4. **Lack of documented evidence for audits:** Security controls and processes are being implemented but lack proper documentation and evidence retention.

   Risk exposure

   - Audit failures or qualified audit opinions
   - Regulatory penalties due to inability to prove compliance
   - Loss of certifications or client trust
5. **Business disruption risk without tested recovery plans:** While recovery strategies may exist, they have not been regularly tested through drills or simulations.

   Risk exposure

   - Extended downtime during actual incidents
   - Financial losses and operational paralysis

11.0 Strategic Recommendations

1. **Establish quarterly executive security governance meetings:** Formalize quarterly security governance meetings involving executive leadership, risk owners, and security stakeholders. These sessions should review risk posture, major incidents, compliance status, vulnerability trends, and remediation progress. This ensures accountability, aligns security with business objectives, and supports risk-based decision-making.
2. **Automate compliance monitoring using dashboards and metrics:** Implement centralized dashboards to track compliance KPIs such as patching SLAs, access reviews, incident response times, vendor assessments, and policy acknowledgments. This aims at eliminating manual tracking errors, improves visibility into control effectiveness, and enables proactive remediation before audit or regulatory issues arise.
3. **Integrate policy attestation into HR onboarding and annual reviews:** Here, employee onboarding workflows should embed policy acknowledgements and require annual re-attestation of security policies and codes of conduct. This ensures employees formally recognize their security responsibilities and helps demonstrate compliance during audits.
4. **Conduct annual internal audits against ISO 27002 controls**: Perform structured internal audits aligned with ISO 27002 control objectives to assess policy implementation, control effectiveness, and documentation maturity. This is a proactive approach that identifies gaps before external audits, supports continuous improvement, and strengthens the organization's information security management practices.
5. **Invest in GRC tooling for tracking compliance obligations**: Adopt a Governance, Risk, and Compliance (GRC) platform to centralize risk registers, control mapping, policy management, and audit evidence. With GRC tooling, we can improve traceability, reduce spreadsheet dependency, streamline audit preparation, and enhance reporting to regulators and leadership.
6. **Embed policy awareness training via Wizer**: Leverage security awareness platforms such as Wizer to deliver engaging, trackable policy and cybersecurity training. Automated phishing simulations and micro-learning modules help reinforce secure behavior, reduce human risk, and provide measurable training completion metrics for compliance reporting.
7. **Maintain documented evidence for audit defensibility**: Ensure all security controls, reviews, approvals, and remediation activities are supported by retained documentation (logs, screenshots, reports, sign-offs). Organized evidence repositories improve audit readiness, demonstrate control effectiveness, and protect the organization during regulatory reviews or investigations.

12.0 Conclusion

The GRC sprint marked a significant transformation in Cyberinfiniti Ltd's security posture, transitioning the organization from largely informal and reactive operational security practices to a structured, policy-driven, and ISO-aligned governance framework. This shift introduced clearly defined roles and responsibilities, formalized oversight mechanisms, and embedded accountability across business functions, ensuring that security is managed as a strategic business priority rather than an ad hoc technical function.

Through the development and implementation of ten comprehensive enterprise security policies, the organization established a cohesive and measurable compliance framework. These policies were not created as standalone documents, but were integrated into operational workflows, risk management processes, and compliance tracking mechanisms to ensure enforceability and sustainability. This structured approach significantly strengthens multiple dimensions of organizational maturity:

- **Governance Maturity:** Clear ownership of security controls, formal review cycles, and defined escalation paths improve decision-making and accountability at all levels.
- **Regulatory Alignment (NDPA 2023):** The framework aligns internal controls with the requirements of the Nigeria Data Protection Act (NDPA 2023), enhancing data protection, privacy management, and regulatory defensibility.
- **Executive Oversight:** Leadership now benefits from improved visibility into risk posture, compliance metrics, and control effectiveness through structured reporting and governance forums.
- **Operational Resilience:** Formalized policies and risk management processes reduce ambiguity during incidents, enabling faster, coordinated, and more effective response and recovery.
- **Audit Readiness:** Documented controls, evidence retention practices, and structured compliance tracking significantly improve preparedness for internal and external audits.
- **Client Assurance:** A demonstrable governance framework enhances trust with partners, financial institutions, and enterprise clients who require strong cybersecurity and compliance controls.

Overall, this initiative establishes a scalable and sustainable governance foundation capable of supporting future ISO 27001 certification efforts, enabling enterprise expansion, and maintaining long-term cybersecurity excellence. It positions Cyberinfiniti Ltd not only to meet current regulatory and operational demands, but also to adapt proactively to evolving threats, compliance requirements, and market expectations.

Appendix A: Sprint Timeline & Meetings

Dates	Times	Attendees
16th-Feb -2026	8:10 pm	John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Blessing Ibe, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun
18th-Feb-2026	8:10 pm	John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun
21st-Feb-2026	8:10 pm	John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Blessing Ibe, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun
25th-Feb-2026	8:10 pm	John Ofulue, Halimat Omorinsola Adepegba, Ikenna Emerole, Blessing Ibe, Andrew Moses, Odunayo Balogun
27th-Feb-2026	8:10 pm	John Ofulue, Halimat Omorinsola Adepegba, Favour Obisike, Ikenna Emerole, Blessing Ibe, Ayodimeji Omole, Divine Ezewele, Andrew Moses, Odunayo Balogun

Appendix B: Team Contributions

Names	**Roles and Responsibilities**
John Ofulue	Team lead, assigned tasks, formulated the InfoSec Policy and assisted in the formulation of the AI policy, Vulnerability management policy, BC/DR policy & assisted in preparing presentation slides.
Halimat Omorinsola Adepegba	Assistant Team Lead. Formulated the Clear Desk and Clear Screen Policy, assisted in BC/DR policy writing, report compilation & presented for the team during the review
Favour Obisike	Formulated the Privileged Account Policy and assisted in the compilation of the team's report
Ikenna Emerole	Formulated the AI policy, compiled and modified the team's report
Blessing Ibe	Formulated the Third party & vendor management policy. Presented for the team during the review
Ayodimeji Omole	Formulated the Incident Management Policy & prepared slides for presentation
Divine Ezewele	Formulated the Identity Management and Access Control Policy & assisted in the vulnerability management & secure testing policy.
Andrew Moses	Proofread the project work for errors, clarity, and alignment with ISO standards and organizational policies.

Odunayo Balogun	Formulated the Information Classification Policy.